Handoff 25: Independent learner plan, checked and published (ID-01)

Date: 2026-10-27 (America/Toronto)
Written by: Claude Code (implementer), in a separate git worktree
For: the human maintainer, and ChatGPT or Claude chat (reviewer) without repository access
Status: **in_review**: one pull request (#PR), documentation only, not merged. No code, content or settings change.

> **How to use this file:** upload it with `docs/plan/independent-learners.md`, `build.md` and `docs/plan/backlog.md`. The pull request diff is the source of truth (`build.md` section 14). Commit `b92de64` is the plan exactly as drafted in chat; the next commit holds every correction, so the diff between them shows what changed.

Starter prompt for the chat assistant

```
You are reviewing Python Academy's plan for independent learner accounts
(ID-01): people 16 or older learning without a parent. It was drafted in
chat, then checked claim by claim against the code on main and against
Google's help pages, and corrected. I'm attaching the plan, build.md,
backlog.md and this handoff. Check that every statement about today's
app matches the source named in section 3 of this handoff, that only the
three owner answers are recorded as decided, that nothing is presented
as legal advice, and that the staged order (privacy and deletion and a
sign-ups switch before opening up) is sound. Explain at a first-year
computer engineering level.
```

1. Step 0 (checks before editing)

Check	Result
`git fetch --all`, `gh pr list --state all`	Done. One open PR: #29 (EDU-04 part 1), not related; this PR is not stacked on it
An ID-01 plan on any branch	**None.** ID-01 is only mentioned (`backlog.md`, `course-catalog.md`, `decision-log.md`, handoff 05); no plan file exists on any local or remote branch
Where the work happened	A separate worktree, `../python-academy-id01`, on a new branch `docs/independent-learners` from `origin/main` at `7d33037` (after PR #28). The main folder and other worktrees were not switched
The draft	`ID01-plan-draft-from-chat.md` was copied in as `docs/plan/independent-learners.md` and committed **unchanged first** (`b92de64`), then **moved out of the main folder** (section 9). It is never committed under its draft name

2. Handoff record (build.md template)

Field	Value
Task	ID-01: verify and publish the independent learner plan drafted in chat
Human goal	A plan the owner can trust: today's behaviour described correctly, Google's rules stated only as Google states them, and nothing presented as decided except the three owner answers

Field	Value
Repository and branch	`torontojohn/python-academy`, branch `docs/independent-learners`
Commits	`b92de64`: the draft as received. Then the corrections, then this handoff
Files changed	`docs/plan/independent-learners.md` (new), this handoff (`.md` and `.pdf`)
Not changed	Any code, content or settings; `docs/plan/backlog.md`; `docs/plan/decision-log.md`
Deployment status	Not requested; documentation only

3. Every claim about today's app, and where it was checked

All on `main` at `7d33037`. "Corrected" means the plan now says something different from the draft.

Plan section	Claim	Source	Verdict
2.1	Roles are `pending`, `parent`, `student`	`User.role` default `'pending'` (`db.py`); `enroll()` sets `student` or `parent` (`main.py`)	True
2.1	A new Google sign-in creates a `pending` user with the subject and email; a verified email is required	`callback()` in `main.py` (`email_verified`, 403 otherwise)	True
2.1	**Added:** every sign-in, even without enrolment, stores a `users` row and a `signed_in` event	`callback()`, `audit(db, user, 'signed_in')`	Added
2.1	Enrolment asks for a date of birth; with an invitation: valid, unused, unexpired, same email, age 13 or more, becomes `student` with `parent_id`	`enroll()`	True; **corrected** to add: ages below 0 or above 120 are refused, there is no upper age for invited students, and the claim is atomic (409 on a second use)
2.1	Without an invitation: age over 25, becomes `parent`; 25 or younger refused with "Parents must be over 25"	`enroll()` (`if age <= 25`)	True
2.1	Only a parent creates invitations: email-bound, seven days, link shared by hand	`invite()` (`current(..., 'parent')`, `timedelta(days=7)`, returns the URL); `build.md` section 2 ("parent shares manually")	True
2.1	Learning routes need role `student`	`current(request, db, 'student')` on `GET/POST` `/api/goal`, `/api/recommendation`, `/api/awards`, `/api/attempts`, `/api/progress`	True; **corrected** to name both goal routes and the public preview routes (`/api/catalog`, `/api/lessons`, `/api/units/…`, `/api/checks/…`, `/api/check`)

Plan section	Claim	Source	Verdict
2.1, 2.4	The family view filters on `User.parent_id == u.id`	`family()`	True; **corrected**: it shows the student's **email** as well as goal, completed lessons and each attempt's lesson and pass state
2.1, 2.4	Admin from `ADMIN_EMAILS` at sign-in; testers are students only, set by the admin	`admin.py` (`admin_at_sign_in`, `is_tester`, `set_tester`); `feedback-security.md` section 1	True
2.4	The admin sees an "account list" for parents	`admin.students()` filters `User.role == 'student'`	**Wrong, corrected**: parents and `pending` accounts are not in the admin list
2.5	An admin can change a role by hand	No admin route does this (`admin.py` registers only `/api/admin/students` and `/api/admin/testers`)	**Corrected**: today only by editing the database
2.1, 4	`users.birthday` stores the date of birth; `parent_id` is nullable	`db.py`	True
4	The daily cap can count `enrolled` events; nothing new needed	`audit(db, u, 'enrolled', u.role)` in `enroll()`; `Event.created` is an ISO UTC timestamp (`now()` in `db.py`)	True
4	Migrations are additive, safe during a deploy, tested on SQLite and PostgreSQL	README "Database changes"; `test_migrations.py` (both engines, upgrade and downgrade)	True
5.1	`events` hold "signed in, signed out, enrolled, goal changed, tester set"	`audit()` calls in `main.py`; `admin.py`	**Corrected** to the real actions: `signed_in`, `signed_out`, `enrolled` (role), `invitation_created`, `goal_chosen`/`goal_skipped` (goal), `practice_saved` (lesson ID); `tester_set`/`tester_cleared` are in the admin's history with the student's ID
5.1	`invitations` hold the invited email, parent, expiry	`Invitation` in `db.py`	True; **corrected** to add the token's SHA-256 digest (never the token) and the used flag
5.1	`attempts` hold code, output, pass state; awards, goals, sessions (hashed ID, times, admin flag); feedback has no user link	`db.py` (`Attempt`, `XpAward`, `BadgeAward`, `LearnerGoal`, `UserSession`, `Feedback` has no `user_id`)	True
5.1	Render's request logs record the IP address and time of each request	`feedback-security.md` section 8	True (as that document states; not re-checked in Render)

Plan section	Claim	Source	Verdict
5.1	"The README and the tests show the app's log lines carry no email, code or message text"	The README says nothing about log contents; the tests do (`test_admin.py` `test_the_admin_list_is_in_no_response_and_no_log`, `test_feedback.py` `test_no_message_code_email_or_user_id_in_any_log_line`)	**Corrected** to cite the tests, not the README
5.1	Sign-in and enrolment log lines "not yet checked"	All `log` / `logging` calls in `backend/app`; uvicorn run locally	**Checked** (section 4)
5.3	Sessions "already cascade" on delete	`sessions.user_id` has `ondelete='CASCADE'`; no other foreign key does; the app sets no SQLite `foreign_keys` pragma	**Corrected**: deletion code must delete in order
5.5, 7	Hosted in Oregon; two Starter services, Basic-256mb, 15 GB, autoscaling off, USD 20 a month baseline	`DEPLOYMENT.md` lines 13 to 15	True; **corrected** wording: the extras are database storage, the workspace subscription, taxes and metered usage
6.1	`DEPLOYMENT.md` and the README say the app is in Testing with test accounts added	`DEPLOYMENT.md` (Google OAuth setup, step 2) says so; the README only says to keep use to test accounts	**Corrected**
6.1	The app requests only `openid email profile`	`oauth.register(..., client_kwargs={'scope': 'openid email profile'})` in `main.py`	True
6.3	Per-address sign-up limits for `signin` and `enroll`, using `CLIENT_IP_HEADER=cf-connecting-ip`	`limits.py` `RULES`; `render.yaml`; `DEPLOYMENT.md`	**Corrected**: `signin` and `signin_callback` are 60 per 10 minutes per address; `enroll` counts per **account** (10 per 15 minutes) because a new user already has a session; 30 per address only when signed out
6.3, 7	Rate limits are in memory	`limits.py` line 3; README; `DEPLOYMENT.md`	True
7	"The README and `DEPLOYMENT.md` say to move the counters to the database first"	Only `DEPLOYMENT.md` says it	**Corrected**
8	`recommend()` is pure, with `RULES_VERSION`; the `university` goal path is py, git, cs, sql, ce	`recommend.py` (`recommend`, `RULES_VERSION = 1`, `GOALS`)	True
5.4	Anonymous feedback: 50 days, at most 90 items	Decision 18 in `backlog.md`; `feedback.py`	True

4. Sign-in and enrolment log lines (the draft said "not yet checked")

Where	What it logs	Personal data?
The app's own lines (`main.py`, `limits.py`, `feedback.py`, `lesson_checks.py`)	Sign-in, sign-out and enrolment write **none**; they add `events` rows. Other lines: the startup migration line; `Rate limited: rule=… scope=…`; the client address diagnostic, off by default (counts, header names and an 8-character keyed hash); the feedback lines; `Story check failed: lesson=… error=… at file:line`	None: no email, date of birth, code or message text
The API access log (uvicorn's default; `render.yaml` does not turn it off)	One line per request: the client address uvicorn sees, method, path **with query string**, status. Run locally: `"GET /auth/google/callback?state=STATEVALUE&code=CODEVALUE HTTP/1.1" 400` and `"POST /api/enroll HTTP/1.1" 401`	**Google's one-time sign-in `code` and `state` are logged.** They are single-use and exchanged at once, so the risk is small, but they are secrets in a log. The date of birth and invitation token are in the enrolment body, which is **not** logged. No email

Not confirmed: which client address appears in the production access log behind Render's proxy, and whether Render's own request logs keep query strings. The plan adds **SEC-11** (proposed): filter query strings from, or turn off, the access log.

5. Google's help pages (sections 6.1 and 6.2)

Re-read on 2026-10-27: publishing status and branding and verification.

Draft statement	What the page says	Result
In Testing, apps asking only for `openid`, email and profile need no listed test users, show no warning, and don't expire	"if your app requests a subset of the following: name, email address, and user profile … through the userinfo.email, userinfo.profile, openid scopes or their OpenID Connect equivalents", users "do not need to be in the trusted user list", "will not see a warning message", and "their authorizations will not expire after 7 days"	Supported; now quoted
Testing: up to 100 listed test users, seven-day expiry otherwise	"up to 100 test users listed in the OAuth consent screen"; "Authorizations by a test user will expire seven days from the time of consent"	Supported
In production any Google account can authorize; verification may be needed for name and logo or for sensitive scopes	"available to any user with a Google Account"; "may be subject to verification before its name and logo are displayed"	Supported. Whether a basic-scopes-only app needs verification is **still unconfirmed** (the page does not say)
Google asks for a home page on a verified domain, a privacy policy **and terms of service**, same URLs	Home page and privacy policy links are required; "The homepage must be hosted on a verified domain you own"; the privacy policy must be the same on the home page and the consent screen. Terms of service: the App Domain "allows you to specify" one; **not stated as required**	**Corrected**: terms of service is optional as far as these pages say; "same URLs" applies to the privacy policy
An `onrender.com` subdomain "cannot be a verified domain you own"	The page says ownership is checked in Google Search Console and does not mention subdomains of a hosting provider	**Corrected to unconfirmed**
The 100-new-user cap applies to unverified apps with sensitive or restricted scopes	"100 new users in total, after the app presents the unverified app screen"; "applies over the entire lifetime of the project"	Supported; now quoted

No new legal claims were added. Section 5.6 (what to read: PIPEDA, the Privacy Commissioner's guidance on young people's consent, cross-border storage) keeps its "not confirmed" marks.

6. Backlog rows (section 10): what changed

Draft	Now	Why
`ID-01` as a new row	The **existing** ID-01 row, updated to in_review	ID-01 already exists in `backlog.md` ("Decide independent adult learner onboarding…")
`ID-01e`: learner level, "same as ASSESS-06"	Dropped; **ASSESS-06** (existing) gets one addition: also asked at onboarding	Two IDs for one item invite drift
`ID-01f`, `ID-01g`	Renamed **ID-01e** (invited group, then publishing) and **ID-01f** (level-based recommendations)	The letters stay consecutive
—	**SEC-11** added (proposed): the Google code in the access log	Found in section 4
`SEC-10`	Kept; dependency "Owner check"	No clash: the backlog has SEC-01 to SEC-09

Format: `backlog.md`'s five columns (ID, priority, item, depends on, status), which is where they'll be pasted; prefixes as in `build.md` section 13; letter suffixes follow the existing `ENG-04b`. None of the new IDs exists yet.

7. How it was checked

Check	Result
Every claim	Read in the source (section 3)
Access log	The API run locally with uvicorn (no Google credentials), with a fake callback and enrolment request
Relative links, anchors, file names	The README link script: **8 checked, 0 problems**. Both Google pages answer 200
GitHub rendering	`gh api markdown` (GitHub's renderer, `gfm`): all 11 tables and 28 headings render; no table left as plain text
Only three items decided	Section 0 keeps the three owner answers; every other recommendation now reads "Recommended, not yet confirmed"
Nothing else changed	Backend **367 passed, 11 skipped** (SQLite), **378 passed** (PostgreSQL); `tsc` and build OK; Playwright **125 passed**

Deliberate-break controls: none; there is no code to break. **Bugs found:** none in code. One finding (the access log, section 4), now a proposed backlog row.

8. Questions for you

1. **SEC-10, the most urgent:** sign in with a Google account that is **not** on your test list. If it works, anyone can already sign in and leave their email in `users`, and the sign-ups switch (ID-01c) should come first. *Recommended, not yet confirmed: check this week.*
2. **SEC-11:** filter query strings from the API's access log, or turn it off? *Recommended, not yet confirmed: filter, so request lines stay useful.*
3. **Plan section 11, questions 2 to 9:** each has a recommended answer, none confirmed.
4. **Terms of service:** Google's pages require a privacy policy but don't say a terms-of-service page is required. Write one anyway? *Recommended, not yet confirmed: yes, short, with the privacy notice (stage A).*

9. Where the draft went

- `ID01-plan-draft-from-chat.md` is **no longer in the main folder**. It was moved to my session's scratch folder, `/private/tmp/claude-502/-Users-DEV-Projects-python-academy/d91ca5bb-1855-42f9-95a1-82f13fcfcfc9/scratchpad/id01/`, which is temporary.
- It is preserved unchanged in this PR's first commit: `git show b92de64:docs/plan/independent-learners.md`.

10. For your docs PR (not edited here)

The rows in plan section 10, plus a stage-table line: "25. ID-01 plan | Independent learner accounts, checked | in_review (handoff 25)", and a decision-log entry recording the three owner answers of 2026-10-27.

11. Next concrete action

Do the SEC-10 check, answer section 8, review and merge. Then stage A (privacy notice and data inventory, ID-01a), or stage C first if SEC-10 shows sign-in is already open.

12. Removing the worktree safely

From the **main** folder, after this PR is merged:

```
cd /Users/DEV/Projects/python-academy
git -C ../python-academy-id01 status --short   # expect nothing, or only ?? frontend/AGENTS.md
rm -f ../python-academy-id01/frontend/AGENTS.md   # generated by Next.js, not part of the project
git worktree remove ../python-academy-id01     # deletes only that folder; refuses if anything is uncommitted
git worktree prune
git branch -d docs/independent-learners         # refuses if the branch is not merged
```

Don't delete the folder in the Finder or with `rm -rf`; Git would keep a stale record of it (`git worktree prune` fixes that).